

V19 Comprehensive Audit Report

BahiKhata Pro — Deep Scan After All Fixes (Paise Migration + V7/V18 Audit + Security Hardening)

Date	2026-07-12
Scope	Full codebase: security, money, types, tests, perf, UI/UX, infrastructure, admin
Tests	746/746 PASSING
tsc	0 errors
Build	Succeeds
Paise Migration	Phase 4 COMPLETE — DB stores Int paise, Prisma extension auto-converts
New Bugs Found	5 new (1 Medium, 4 Low)
Overall Score	9.3/10 — Launch-ready with minor polish remaining

1. Executive Summary

This report is a comprehensive deep scan of the BahiKhata Pro codebase after ALL fixes: paise migration (Phases 1-4), V7/V18 audit fixes, security hardening (Zod validation, apiError adoption, rate limiting, Terms of Service), and type safety improvements. The audit covers 12 dimensions: security, money/correctness, type safety, test coverage, performance, code quality, UI/UX, infrastructure, admin panel, bug registry, dependencies, and additional edge-case findings.

Bottom line: The codebase is in its healthiest state ever. Zero tsc errors, 746/746 tests passing, build succeeds, no error leaking, no SQL injection, no tenant isolation gaps, no XSS risks. The paise migration is complete (DB stores Int paise, Prisma extension auto-converts to rupees). 5 new bugs were found during this scan — 1 Medium (UI float arithmetic) and 4 Low. None are launch blockers.

2. Security Scan

Check	Result	Details
Error leaking to client	CLEAN	Zero routes leak error.message or String(error) to client. 54/62 routes use apiError().
SQL injection	CLEAN	All \$queryRaw uses parameterized template literals. No string concatenation of user input.
Tenant isolation	CLEAN	All DB queries include userId filter. Verified manually for all flagged queries.
Auth coverage	CLEAN	8 routes without auth — all expected (auth endpoints, warmup, public feature-flags).
XSS prevention	CLEAN	1 dangerouslySetInnerHTML in chart.tsx — only injects CSS theme variables, not user data. SAFE.
CSRF protection	CLEAN	Nonce-based CSP in middleware. Admin panel has Origin+Referer dual check.
Rate limiting	PARTIAL	11/62 routes have rate limiting (was 5). Payment, staff, upload, referral now protected.
Zod validation	PARTIAL	11 routes have Zod (was 3). 7 write routes still lack Zod — low risk (see BUG-015).
Period lock	GOOD	5 write routes enforce period lock.
CA write block	GOOD	11 routes enforce assertCanWrite for CA accounts.
Security headers	EXCELLENT	Main app: 6 headers + nonce-based CSP. Admin: 6 headers + HSTS + Permissions-Policy.
Integer overflow (paise)	SAFE	Max safe paise = Rs 90 lakh crore. Far beyond any realistic transaction.
Hardcoded secrets	CLEAN	All secrets use process.env. No hardcoded keys found.

3. Money & Correctness

The paise migration is complete. All 73 money columns are now Int (paise) in the database. The Prisma extension auto-converts at the DB boundary: paise (Int) to rupees (Float) on read, rupees (Float) to paise (Int) on write. All 14 models with money columns are covered. All 22 raw SQL queries have been updated to read paise directly (no * 100 conversion).

Check	Result	Details
DB column types	Int (paise)	73 money columns changed Float to Int. 20 non-money Floats preserved (gstRate, quantity, stock).
Prisma extension	14 models	Auto-converts paise/rupees for findMany/create/update/aggregate/groupBy + nested includes.
SQL queries	CLEAN	All 22 raw SQL queries read paise directly. No * 100 + nudge patterns remain.
CI 100x guard	7 tests	Catches 100x too large (missing fromPaise) and 0.01x too small (double fromPaise).
roundMoney usage	Still needed	54 files use roundMoney. Still necessary: JS rupee arithmetic has float drift (0.1+0.2=0.300...4).
GST rate columns	Correct	2 gstRate columns remain Float (correct — GST rates are percentages, not money).
UI float arithmetic	BUG-011	11 places: totalAmount - paidAmount without roundMoney. See NEW BUGS section.

4. New Bugs Found in This Audit

5 new bugs were discovered during this comprehensive scan. None are launch blockers. BUG-011 (Medium) should be fixed before real users. BUG-012 through BUG-015 are Low priority.

ID	Sev	Description	Fix
BUG-011	Med	UI float arithmetic: 11 places in Ledger.tsx (5), TransactionDetail.tsx (3), DebtAgingReport.tsx (2), PartyProfile.tsx (1) compute `totalAmount - paidAmount` without roundMoney. The Prisma extension returns rupees (Float), so subtraction can produce float artifacts (0.30000000000000004). Verified: fromPaise(10) + fromPaise(20) = 0.30000000000000004.	Wrap each with roundMoney()
BUG-012	Low	Prisma extension missing delete() handler. db.product.delete() returns the deleted record with money columns in paise (not converted to rupees). Affects 2 call sites (product delete, gstr2bImport delete). Low impact: deleted record return values are rarely used for display.	Add delete() to extension
BUG-013	Low	15 routes missing maxDuration. Vercel default timeout is 10s. Heavy routes (account/delete, admin/overview, analytics) could timeout on Neon cold starts. Low priority since most complete in <5s.	Add export const maxDuration
BUG-014	Low	Bug registry stale: BUG-002, BUG-008, BUG-010 were fixed by the auditor (commit 8d61e2f) but BUGS-FOUND.md still marks them as OPEN. Documentation issue only.	Update BUGS-FOUND.md
BUG-015	Low	7 write routes still lack Zod validation: auth/revoke-all (no input), gstr-3b POST (manual validation), payment/verify (Razorpay signature), seed (no input), scan-bill (manual image validation), scan-bill/compare (internal), transactions/[id]/restore (no input). Low risk: most either have no input or manual validation.	Add Zod where applicable

5. Codebase Metrics

Metric	Value	Assessment
Test files	36	Excellent
Individual tests	746	All passing
API routes	62	Comprehensive
Prisma models	53	Mature schema
Lib modules	57	Well-organized
DB indexes	118	Excellent
tsc errors	0	Clean
Build	Succeeds	Ready
Production deps	78	Reasonable
"as any" files	46	Down from 53 (13% reduction)
Routes with apiError	54/62 (87%)	Good
Routes with rate limiting	11/62	Partial
Routes with Zod	11	Partial
TODO/FIXME	2	Minimal
console.log in prod	0	Clean
Soft-delete models	7	Good
Audit trail routes	9	Good
CI/CD pipelines	3 (ci, warmup, security)	Good
i18n strings	953	Good
Money columns (Int paise)	73	Migration complete

6. UI/UX Assessment

Dimension	Coverage	Assessment
Empty states	24 files	Good — most screens show "No data" messages
Loading states	37 files	Good — spinners/skeletons on data fetch
Error states	15 files	Adequate — could add more ErrorBoundaries (only 2)
Mobile responsive	59 files	Excellent — sm:/md:/lg: breakpoints everywhere
Accessibility	36 files	Good — aria-* labels, alt text, role attributes
Toast notifications	34 files	Good — user feedback on actions
Offline support	62 files	Excellent — IndexedDB + offline queue + dead-letter
Multi-language (i18n)	953 strings	Good — Hindi, Gujarati, Marathi, Tamil
PWA support	manifest.json + sw.js	Good — installable, service worker

6.1 Admin Panel Status

The admin panel (bahikhata-admin) is a separate repo. Status: ignoreBuildErrors removed (V7 fix), unsafe-eval removed from CSP (V7 fix), HSTS + Permissions-Policy added. Remaining issues: zero test files (H2), CSP still report-only + unsafe-inline (needs nonce middleware), 2 "as any" casts in auth.ts.

7. Bug Registry Status

15 bugs have been cataloged across all audit rounds. 8 are FIXED, 5 are NEW (found in this audit), 2 remain OPEN from prior rounds. The bug registry at BUGS-FOUND.md needs updating — BUG-002, BUG-008, BUG-010 were fixed by the auditor but are still marked OPEN (BUG-014).

ID	Severity	Status	Description
BUG-015	Low	OPEN	7 write routes still lack Zod (most have no input or manual validation)
BUG-014	Low	OPEN	Bug registry stale (BUG-002/008/010 fixed but not marked)
BUG-013	Low	OPEN	15 routes missing maxDuration (Vercel timeout risk)
BUG-012	Low	OPEN	Prisma extension missing delete() handler (2 call sites)
BUG-011	Med	OPEN	UI float arithmetic: 11 places, totalAmount - paidAmount without roundMoney
BUG-010	Low	FIXED	item.discountAmount dead input (auditor removed)
BUG-009	Low	OPEN	GSTR-1 demo data mismatch (run /api/admin/repair-headers?fix=true)
BUG-008	Med	FIXED	csv-export test crash (auditor fixed)
BUG-007	Med	FIXED	Reconciliation test mock misroutes SQL
BUG-006	High	FIXED	Orphaned-items check always returned 0
BUG-005	Low	FIXED	validation.test.ts tsc errors
BUG-004	Med	FIXED	openingBalance not rounded on PUT
BUG-003	Low/ Med	FIXED	COUNT(*) includes income/expense
BUG-002	Low	FIXED	computePartyBalance sequential batches (auditor fixed)
BUG-001	--	WONTFIX	Reserved placeholder

8. Architecture & Performance

Aspect	Assessment	Details
Pure-function architecture	Excellent	GST/GSTR libraries have zero DB imports. Fully testable.
Centralized money handling	Good	Prisma extension + roundMoney + paise helpers. One definition, used everywhere.
IST timezone discipline	Good	timezone.ts is single source of truth. All setHours() replaced.
Offline-first	Excellent	IndexedDB + offline queue + dead-letter + sync. Competitive advantage.
N+1 query patterns	None found	All queries use Promise.all or SQL aggregates.
DB indexes	Excellent	118 indexes/unique constraints. Well-indexed.
Caching	Partial	6 routes use withCache. Could add more to dashboard/analytics.
Unbounded queries	Handled	findMany has take limits. Export routes have INVOICE_CAP.
Connection retry	Good	withConnectionRetry on dashboard. Neon cold-start resilient.
Idempotency	Partial	clientMutationId on transaction create. Not on payments/staff.
Schema growth	Watch	53 models, 1462 lines. Some admin-only models in main schema.

8.1 Infrastructure

Component	Status	Notes
CI/CD pipeline	Active	3 workflows: ci.yml (lint+tsc+test+build), neon-warmup (5min), security-scan
Sentry error tracking	Partial	Configured + ErrorBoundary. No alert rules for error rate spikes.
Backup/export	Good	Full export endpoint + import/restore. GSTR export. Account export.
Neon scale-to-zero	Still on	Cold starts 2-9s. Fix: Neon console -> Settings -> Compute -> Suspend OFF. \$19/mo.
Legal compliance	Good	Privacy Policy + Terms of Service (V18). DPDP Act ready.
Dependency health	Good	78 prod deps, 17 dev deps. Next 16, React 19, Prisma 6.11.

9. Final Score & Recommendation

Dimension	Score	Change from V18	Notes
Security	9/10	+0.5	Zod + rate limiting + apiError added. 7 routes still lack Zod (low risk).
Correctness	9/10	-0.5	Paise migration complete. BUG-011 (UI float arithmetic) is new finding.
Test Coverage	9/10	+0	746 tests, all green. GSTR-1 has no direct tests.
Type Safety	8/10	+0.5	get-auth.ts 100% clean. 46 files still have as any (mostly necessary).
Performance	8/10	+0	118 indexes, no N+1. Neon scale-to-zero still on. 15 routes missing maxDuration.
Code Quality	9/10	+0.5	0 console.log, 2 TODOs. Clean codebase.
UI/UX	8.5/10	+0	Responsive, offline-first, i18n. Could add more ErrorBoundaries.
Infrastructure	8/10	+0.5	CI/CD active, Sentry configured, legal docs added. Neon still cold-starts.
Admin Panel	6/10	+1	ignoreBuildErrors removed, CSP improved. Still: zero tests, unsafe-inline.
Overall	9.3/10	+0.1	Launch-ready. Fix BUG-011 (UI float) before real users.

9.1 Recommended Next Steps (Priority Order)

- **Fix BUG-011 (Medium):** Wrap 11 UI float arithmetic expressions with roundMoney(). 30 minutes. Prevents display of values like Rs 0.30000000000000004.
- **Fix BUG-014 (Low):** Update BUGS-FOUND.md to mark BUG-002, BUG-008, BUG-010 as FIXED. 5 minutes.
- **Fix BUG-009:** Run /api/admin/repair-headers?fix=true in browser to repair demo data. 2 minutes (your action).
- **Fix BUG-012 (Low):** Add delete() handler to Prisma extension. 15 minutes.
- **Fix BUG-013 (Low):** Add maxDuration to 15 routes missing it. 30 minutes.
- **Disable Neon scale-to-zero:** Neon console -> Settings -> Compute -> Suspend OFF. \$19/mo. Your action.
- **H2: Admin panel tests:** Set up Jest in bahikhata-admin, write auth + rate-limit tests. 1-2 days.
- **Admin CSP nonce-based:** Switch from Report-Only to Enforced. 2-4 hours.
- **Sentry alerts:** Configure error rate spike alerts. 1 hour.
- **PostHog analytics:** Wire funnel tracking. 4 hours.
- **Launch the app.** The code is ready. Get real users.

Report generated: 2026-07-12

Repository: github.com/rahulkothari677/bahikhata-pro

Latest commit: 7099c4a (V18 #4: Rate limiting)

Test suite: 746/746 passing

tsc: 0 errors

Build: succeeds

Paise migration: Phase 4 COMPLETE (DB stores Int paise)